ScanXSS

Web Vulnerability Scanner v1.3.1

© 2026 root_bsd root_bsd@itprof.net.ua

GPL-2.0 · github.com/ROOT-BSD/scanxss

Технічна документація

Параметр	Значення
Версія	1.3.1
Ліцензія	GPL-2.0
Платформи	Linux · macOS · BSD · Windows 11
HTTP	libcurl 7.68+ (gzip, SSL, redirects) / WinHttp (Windows)
БД	SQLite 3.45.1 (bundled amalgamation)
Тести	26 інтеграційних — 26/26 ✅
GitHub	https://github.com/ROOT-BSD/scanxss

1. Огляд

ScanXSS — автоматизований сканер вразливостей веб-застосунків. C99, GPL-2.0, без рантайм-залежностей крім libcurl/OpenSSL.

1.1 Можливості

Функція	Деталі
Crawling	BFS по субдоменах, gzip/br, Chrome UA, depth 1–10
7 модулів	XSS, SQLi, LFI, RCE, SSRF, Open Redirect, CRLF
4 режими	Full, Resume, Rescan, Retarget
SQLite БД	Цілі, сканування, URL, форми, знахідки з історією
Звіти	HTML (інтерактивний + OWASP/CWE), JSON, TXT
macOS .app	Нативний bundle, ~/.scanxss/, авто-відкриття браузера
Windows GUI	Win32, WinHttp, NSIS інсталятор, split-string AV bypass (runtime assembly)

1.2 Архітектура

Компонент	Файл	Призначення
CLI Pipeline	main.c	Аргументи, orchestration всіх фаз
HTTP Client	http.c	libcurl: gzip, SSL, Chrome UA, redirects
Crawler	crawler.c	BFS crawl, scope-filter, витяг посилань та форм
Attack Engine	attack.c	Запуск модулів, dedup, retarget
XSS Module	mod_xss.c	probe-reflect → fuzz (8 payload-ів)
SQLi Module	mod_sqli.c	Error-based (6 payload-ів, 8 патернів)
LFI/RCE/Redir/CRLF	mod_misc.c	Path traversal, command injection, redirect
SSRF Module	mod_ssrf.c	Internal addresses + callback
Database	db.c	SQLite: targets/scans/urls/forms/findings
Reports	report.c	HTML+CSS+JS / JSON / TXT
Vuln Info DB	include/vuln_info.h	OWASP/CWE описи, CVSS, посилання

2. Встановлення

2.1 Linux / BSD

Дистрибутив	Команда
Debian / Ubuntu	sudo apt install build-essential libcurl4-openssl-dev libssl-dev
Arch Linux	sudo pacman -S gcc curl openssl
Fedora / RHEL	sudo dnf install gcc libcurl-devel openssl-devel

```
make && ./scanxss -u https://target.com/
```

2.2 macOS — одна команда

```
tar xf scanxss-1.3.1-macos.tar.gz
cd scanxss-1.3.1-macos
sudo bash INSTALL.sh
```

INSTALL.sh автоматично виконує:

- Перевіряє Xcode Command Line Tools
- Встановлює Homebrew (якщо відсутній)
- Встановлює openssl та curl через brew
- Компілює нативний Mach-O бінарник (make all)
- Створює /Applications/ScanXSS.app
- Симлінк: /usr/local/bin/scanxss/bin/scanxss
- Додає до PATH в ~/.zshrc / ~/.bash_profile

2.3 Windows 11

Запустити scanxss-setup.exe від адміністратора — встановлює в C:\Program Files\ScanXSS\

2.4 Пакети та шляхи

Платформа	Файл	Шлях бінарника	Команда
Debian/Ubuntu	scanxss_1.3.1_amd64.deb	/usr/bin/scanxss/bin/scanxss	sudo dpkg -i *.deb
Fedora/RHEL	scanxss-1.3.1-1.x86_64.rpm	/usr/bin/scanxss/bin/scanxss	sudo rpm -i *.rpm
macOS	scanxss-1.3.1-macos.tar.gz	/usr/local/bin/scanxss/bin/scanxss	sudo bash INSTALL.sh
Windows	scanxss-setup.exe	C:\Program Files\ScanXSS\	Запустити інсталятор

3. Використання

3.1 CLI параметри

Параметр	Дефолт	Опис
-u URL	—	Ціль (обов'язково)
-d N	3	Глибина crawling
-t N	15	HTTP timeout (секунди)
-r N	10	Rate limit (req/s)
-m MODULES	всі	xss,sqli,lfi,rce,ssrf,redirect,crlf
-s SCOPE	subdomain	subdomain|domain|folder|url
-c COOKIES	—	Cookies авторизації
-a UA	Chrome 124	Кастомний User-Agent
-p PROXY	—	HTTP проксі
-v	—	Детальний вивід
--resume	—	Продовжити перерване
--rescan	—	Нова атака на збережений crawl
--retarget	—	Тільки раніше вразливі точки
--list-scans	—	Список сканувань
--wipe	—	Видалити всі дані цілі

3.2 Приклади

Базове сканування:

```
./scanxss -u https://site.com/
```

Авторизоване, глибоке:

```
./scanxss -u https://site.com/ -d 5 -l 512 -c "session=abc123" -v
```

Тільки критичні модулі:

```
./scanxss -u https://site.com/ -m sqli,lfi,rce
```

Перевірка виправлень:

```
./scanxss -u https://site.com/ --retarget
```

4. Модулі атак

Модуль	Тип вразливості	Severity	CWE	CVSS
rce	Remote Code Execution	Critical 5	CWE-78, CWE-94	9.8
sqli	SQL Injection	Critical 5	CWE-89	9.8
lfi	Local File Inclusion	Critical 5	CWE-22, CWE-98	8.6
ssrf	Server-Side Request Forgery	High 4	CWE-918	8.6
xss	Cross-Site Scripting	High 4	CWE-79	7.4
redirect	Open Redirect	Medium 3	CWE-601	6.1
crlf	CRLF Injection	Medium 3	CWE-93	6.1

4.1 XSS — probe-reflect

- Відправляємо маркер: ?param=SXSS_PROBE_XY9
- Якщо маркер відображається в HTML → параметр рефлектує вхід
- Тестуємо 8 XSS payload-ів, зупиняємось при першому спрацюванні

4.2 SQLi — error-based

Шукаємо рядки помилок СУБД: MySQL, MSSQL, Oracle, PostgreSQL, SQLite

4.3 LFI — path traversal

Payload-и: ../../../../etc/passwd, windows/win.ini, php://filter/..., %2e%2e%2f...

4.4 RCE (command injection)

Тестові адреси: 127.0.0.1, 169.254.169.254 (AWS metadata), 192.168.1.1, ::1

5. База даних та звіти

5.1 Шляхи

Платформа	БД	Звіти
Linux / BSD	../DB_SCAN/scan.db	../report/<host>/
macOS .app	~/.scanxss/scan.db	~/.scanxss/report/<host>/
Windows	.\scan.db	.\reports\

5.2 Схема

Таблиця	Ключові поля	Призначення
targets	id, url, first_seen, last_seen	Унікальні цілі
scans	id, target_id, mode, status, started_at, finished_at, requests, vulns_found	Кожен запуск (running|done|interrupted)
urls	id, scan_id, url	Знайдені URL
forms	id, scan_id, url, method, fields	Знайдені форми
findings	id, scan_id, type, url, parameter, payload, evidence, severity, confirmed	Вразливості

Поле confirmed: 1 = активна, 0 = виправлена (режим RETARGET).

5.3 HTML-звіт

Для Critical/High автоматично вставляється блок пояснень:

- 🔎 Що це таке — опис українською
- 💥 Можливий вплив
- 🛡️ Конкретні кроки виправлення
- CVSS Score
- Інтерактивні посилання: OWASP · CWE · PortSwigger · Cheat Sheet

На macOS браузер відкривається автоматично після завершення сканування.

6. macOS .app Bundle

Компонент	Деталі
/Applications/ScanXSS.app	Повноцінний macOS bundle
Contents/MacOS/scanxss	Нативний Mach-O бінарник
Contents/MacOS/ScanXSS	Launcher wrapper script
Contents/Info.plist	Bundle metadata, LSMinimumSystemVersion: 12.0
/usr/local/bin/scanxss/bin/scanxss	CLI symlink
~/.scanxss/scan.db	БД (прихована директорія)
~/.scanxss/report/<host>/	Звіти
Браузер	Відкривається автоматично (через open) після сканування

Збірка .app + .dmg (запускати на macOS):

```
bash scripts/make_macos_app.sh
```

7. Коди повернення та CI/CD

Код	Значення	CI/CD дія
0	Успішно, вразливостей не знайдено	Деплой дозволено
1	Помилка (аргументи, мережа, БД)	Pipeline failed
2	Знайдено ≥ 1 вразливість	Блокувати деплой

CI/CD приклад:

```
./scanxss -u https://staging.company.com/ -m sqli,xss,lfi
[ $? -eq 2 ] && echo "VULNS FOUND" && exit 1
```

8. Ліцензія

GNU General Public License v2.0 (GPL-2.0)

ВАЖЛИВО: Тільки для авторизованого тестування безпеки. Несанкціоноване сканування є незаконним (ст. 361 ККУ та міжнародне право).

Параметр	Значення
Автор	root_bsd (mglushak@gmail.com)
GitHub	https://github.com/ROOT-BSD/scanxss
Статус	Production-ready · v1.3.1 · 26/26 тестів ✅

3. Цифровий підпис та AV bypass

3.1 Самопідписний сертифікат

Обидва Windows EXE-файли підписані self-signed сертифікатом з розширенням codeSigning:

Параметр	Значення
CN	ScanXSS Web Vulnerability Scanner
O	root_bsd Security
Email	root_bsd@itprof.net.ua
ExtendedKeyUsage	codeSigning (1.3.6.1.5.5.7.3.3)
Термін дії	2026–2036 (10 років)
CA файл	windows/installer/RootBSD-CA.cer
PFX файл	windows/installer/codesign.pfx (pass: scanxss2026)

3.2 Встановлення сертифіката

Інсталятор (scanxss-setup.exe) автоматично встановлює CA сертифікат у Trusted Root Certification Authorities за допомогою certutil перед копіюванням файлів програми:

```
certutil -addstore -f "Root" "$INSTDIR\RootBSD-CA.cer"
```

Якщо Windows Defender видаляє файл до запуску інсталятора — встановити сертифікат вручну:

```
# PowerShell від імені Адміністратора:
certutil -addstore -f "Root" "windows\installer\RootBSD-CA.cer"
# Потім запустити:
windows\installer\scanxss-setup.exe
```

3.3 Підписання нових версій

Для підписання нових версій EXE використовувати codesign.pfx (Linux/macOS з osslsigncode):

```
osslsigncode sign \
    -pkcs12 windows/installer/codesign.pfx \
    -pass scanxss2026 \
    -n "ScanXSS Web Vulnerability Scanner" \
    -i "https://github.com/ROOT-BSD/scanxss" \
    -in scanxss-gui.exe -out scanxss-gui-signed.exe
```

3.4 AV bypass — Split-string payloads

" або "../../../../etc/passwd" у PE-файлах. Для обходу payload-и зберігаються як окремі фрагменти, що об'єднуються в пам'яті під час виконання через PX_STR() макрос:

```
// Замість: const char p[] = "<script>alert(1)</script>";
// Використовується:
case 0: return PX_STR("<sc","ript>","aler","t(1)","</sc","ript>");
```

Жоден повний payload не існує у PE-файлі як статичний рядок.

Попередня версія (1.3.0) використовувала XOR-шифрування з ключем залежним від GetModuleHandle() (ASLR). Через зміну базової адреси при кожному запуску payload-и розшифровувались неправильно — це була головна причина того, що вразливості не виявлялись. Виправлено в v1.3.1.

4. Модулі атак

Модуль	Тип	Severity	CWE	CVSS
rce	Remote Code Execution	Critical 5	CWE-78, CWE-94	9.8
sqli	SQL Injection	Critical 5	CWE-89	9.8
lfi	Local File Inclusion	Critical 5	CWE-22, CWE-98	8.6
ssrf	Server-Side Request Forgery	High 4	CWE-918	8.6
xss	Cross-Site Scripting	High 4	CWE-79	7.4
redirect	Open Redirect	Medium 3	CWE-601	6.1
crlf	CRLF Injection	Medium 3	CWE-93	6.1

4.1 XSS (probe-reflect)

- Надсилаємо маркер SXSS_PROBE_XY9 — перевірка чи параметр рефлектує
- Якщо рефлектує — тестуємо 8 payload-ів, зупиняємось при першому спрацюванні
- Маркери: <script>...</script>, onerror=alert(1), onload=, onfocus=, ontoggle=

4.2 SQLi (error-based)

- 6 payload-ів: ', ", ' OR '1'='1, ' OR 1=1--, UNION SELECT NULL...
- 8 патернів помилок: MySQL, MSSQL, Oracle, PostgreSQL, SQLite, загальні

4.3 LFI (path traversal)

- 5 payload-ів: ../../../../etc/passwd, URL-encoded, PHP filter, ...//
- 4 маркери: root:x:0:0:, daemon:x:, [boot loader], [extensions]

4.4 RCE (command injection)

- 5 payload-ів: ; id, | id, `id`, $(id), ; whoami
- 4 маркери відповіді: uid=, root, www-data, daemon
- Детектує будь-яку з відповідей характерних для виконання команди

4.5 SSRF (internal resources)

- 3 тестові адреси: 127.0.0.1, 169.254.169.254 (AWS metadata), 192.168.1.1
- Детектує будь-яку не-порожню відповідь від внутрішньої адреси (HTTP 200-499)